

Ciência de Dados

Aula 02 - Governança de Dados, Segurança e LGPD

Rafael Duarte

rduarte@up.edu.br

O "Novo Petróleo" e seus Riscos

O Paradigma do Valor

Ouve-se constantemente que dados valem mais que petróleo. Empresas operam para capturar cliques, transações e métricas de usuários visando gerar "valor de negócio" e vantagem competitiva.

A Gestão de Passivos

A contrapartida técnica: armazenar dados é acumular passivo e risco. Vazamentos quebram a confiança do mercado e geram multas severas. Se uma coluna não é vital para o negócio, não a armazene.

A Tríade CIA (A Base da Governança)

Governança vai muito além do backup técnico. Trata-se de gerenciar permissões, integridade e rastreabilidade. Tudo se apoia nos pilares da Segurança da Informação:

Confidencialidade

O dado só pode ser lido por quem possui autorização estrita. (Aplicação de criptografia e IAM).

Integridade

Garantia de que o dado não foi adulterado no armazenamento ou no trânsito. (Uso de Hashes e Auditoria).

Disponibilidade

O dado e o sistema devem estar acessíveis de forma ininterrupta e confiável. (Redundância, SLAs).

O Mapa Global da Privacidade

Arquitetura sem Fronteiras

Sistemas em nuvem têm alcance global. Operar dados de cidadãos estrangeiros exige conformidade com regulações internacionais.

- **GDPR (União Europeia):** O marco regulatório mais severo. As penalidades alcançam até 20 milhões de Euros ou 4% do faturamento global da empresa.
- **CCPA (EUA/Califórnia):** Foco substancial no direito do consumidor de proibir a venda de suas informações ("Do Not Sell My Personal Information").
- **LGPD (Brasil):** Lei 13.709/18, profundamente inspirada na GDPR. Sanções chegam a R\$ 50 milhões por infração.

Tradução da LGPD para TI

A Premissa: O Titular (Usuário) é o proprietário legítimo dos dados.

Para justificar o processamento ou armazenamento em banco de dados, o projeto deve respeitar três princípios essenciais:

- **1. Finalidade:** Qual o propósito exato da coleta? O motivo deve ser claro, documentado e não genérico.
- **2. Adequação:** Os dados coletados são realmente compatíveis com a finalidade informada?
- **3. Minimização (Need-to-Know):** Capturar o mínimo necessário. Ex: Para validar maioridade, armazene um booleano (`maior\_idade = True`) em vez de coletar a data de nascimento completa.

Dado Pessoal vs. Dado Sensível

Dado Pessoal

Qualquer informação que identifique ou possa identificar uma pessoa de forma direta ou indireta.

- Nome e CPF
- E-mail e Telefone
- Placa de veículo
- Endereço IP / Geolocation

Dado Sensível

Dados pessoais que carregam potencial de discriminação social ou financeira. O rigor de segurança é máximo.

- Raça e Etnia
- Convicções Religiosas e Políticas
- Dados de Saúde e Genéticos
- Biometria e Orientação Sexual

O Impacto nos Negócios e Operações

Onde o cotidiano fere a legislação

- **O "CPF na Nota" (Varejo e Farmácias):** Exigir o CPF sob a premissa de "desconto", mas utilizar esses dados ocultamente para mapear padrões de saúde ou consumo visando revenda a terceiros (Clara infração de Desvio de Finalidade).
- **O Cartão da Loja:** Solicitar dados excessivos (estado civil, profissão, dados de familiares) alegando "análise de crédito", e aproveitar a base para bombardear o cliente com marketing agressivo sem o Opt-in adequado.
- **Compartilhamento Silencioso:** O cliente finaliza uma compra e, dias depois, passa a receber ligações de corretores oferecendo seguros. O compartilhamento de base de dados entre empresas parceiras sem transparência é violação grave.

Anti-Patterns Clássicos de Arquitetura

Onde a engenharia e os processos falham

- **Logs Expostos (Data Leakage):** Uma aplicação falha, e o desenvolvedor instrui o sistema a gravar o payload da requisição integral no arquivo de log, armazenando senhas ou cartões de crédito em texto plano.
- **Bases de Produção em Homologação:** Realizar cópias do banco de dados real dos clientes para ambientes de teste (Staging) ou para as máquinas locais da equipe de desenvolvimento.
- **A Síndrome do Exportar para Excel:** Sistemas corporativos que possuem permissões irrestritas de download de tabelas em `.csv`, desprovidos de limites de linhas, paginação ou logs de auditoria de quem exportou os dados.

O Paradoxo do Acesso (IAM)

Princípio do Menor Privilégio

Um usuário corporativo ou microsserviço deve possuir apenas o nível exato de permissão necessário para cumprir sua atribuição técnica.

A Falha Operacional

Conceder acessos administrativos irrestritos ou permissões ``SELECT *`` para desenvolvedores iniciantes diretamente na base de produção. O vazamento de apenas uma dessas credenciais compromete a organização inteira.

O Sistema "Hotel Califórnia"

"You can check out any time you like, but you can never leave."

Complexidade de Opt-Out e Dark Patterns

- Sistemas que permitem o cadastro em um clique (via OAuth), mas exigem interações complexas, telefonemas ou e-mails formais para o encerramento da conta.
- À luz da LGPD, o consentimento para uso de dados deve ser fácil de fornecer e igualmente acessível para ser revogado.
- A ausência de interfaces claras para a revogação de dados caracteriza não-conformidade sistêmica.

Soluções para o "Direito ao Esquecimento"

O Conflito Técnico

O cliente exige a exclusão total de seu perfil.

Impacto:

Aplicações com alta normalização não suportam um `DELETE` absoluto na tabela de usuários sem corromper a integridade referencial de tabelas fiscais e logísticas (cujo arquivamento é exigência legal de longo prazo).

Arquitetura de Soft Delete

```
UPDATE usuarios  
SET nome = 'ANON', email = 'anon@hash',  
    telefone = '0000', is_ativo = false  
WHERE id_usuario = 159;
```

As relações de faturamento permanecem híginas, os requisitos fiscais são cumpridos, e a anonimização lógica desvincula as informações pessoais do titular.

Setores Críticos de Vulnerabilidade

Áreas que demandam treinamentos constantes

Marketing e Vendas

Aquisição de "listas de e-mails" externas (sem consentimento) e importação indiscriminada no CRM para disparo de campanhas, resultando em SPAM ilegal.

Recursos Humanos

Recepção de milhares de currículos contendo dados pessoais, frequentemente compartilhados em canais não oficiais (WhatsApp) sem diretrizes de descarte após o processo.

Atendimento (CX)

Trafiar capturas de tela contendo painéis do sistema (e informações financeiras de clientes) por meio de chats corporativos (Teams, Slack) para solicitar suporte técnico.

O Inimigo Invisível: Shadow IT

A TI das Sombras

Refere-se ao uso de softwares, aplicações em nuvem ou dispositivos não homologados e não auditados pelo departamento de TI para contornar bloqueios institucionais.

- Exemplo 1: Exportar relatórios gerenciais e aloca-los em contas pessoais no Google Drive.
- Exemplo 2: Inserir bases de dados não anonimizadas em IAs gerativas públicas (como o ChatGPT) para agilizar formatações ou análises, expondo o banco ao treinamento algorítmico global da OpenAI.

A Governança de TI não pode proteger aquilo que ignora existir.

Dinâmica da Oficina Prática

Relatório Técnico de Governança

- Apresentaremos 2 Cenários de Negócios e Arquitetura.
- Dinâmica: 10 minutos de debate nos grupos + 10 minutos de resolução guiada na lousa.
- A Entrega: Produzir um Relatório Técnico formal pontuando as vulnerabilidades e sugerindo intervenções na arquitetura e nos processos.
- Envio via Blackboard até o fim da aula (Avaliação Contínua).



Momento da Chamada

INTERVALO

Retorno para os Laboratórios de Arquitetura

O Caso da HealthTech

Contexto Institucional: Uma HealthTech (startup) mantém um app de monitoramento via smartwatches. A diretoria fechou uma parceria B2B para transferir o fluxo de dados integral (via JSON) para uma Seguradora Parceira, visando o treinamento de um modelo preditivo de seguro de vida.

O Payload exportado contém:

```
id_usuario, nome, email, data_nasc, batimento_cardiaco_medio,  
doenca_pre_existente, geo_lat_long_tempo_real, renda_mensal
```

Pauta para o Relatório (10 min):

- 1. Identifique as vulnerabilidades jurídicas e separe as PII dos Dados Sensíveis.
- 2. Proponha uma arquitetura de dados (técnicas de Drop, Hashing ou Agrupamento) para higienizar o JSON antes do envio, preservando o valor analítico para a Seguradora.

Gabarito: Discussão do Cenário 1

Mapeamento de Riscos e Intervenções de Arquitetura:

- Vulnerabilidade Crítica: Exportar a base em estado bruto cruza PII diretas com condições médicas, gerando um risco extremo de viés e precificação discriminatória de seguros de vida.
- **Estratégia de DROP:** Eliminar colunas `nome` e `email`. Modelos de Machine Learning não utilizam nomenclatura civil para o cálculo de propensão de risco.
- **Estratégia de Hashing:** O `id\_usuario` deve ser convertido (ex: SHA-256) para garantir a consistência das tabelas relacionais sem exposição de identidade direta.
- **Estratégia de Agrupamento/Anonimização:** Transformar `data\_nasc` em categorias ("Faixa Etária") e `geo\_lat\_long` em "Macrorregião". As métricas clínicas são mantidas, viabilizando a regressão estatística para a Seguradora sem ferir a LGPD.

Modelagem Preditiva Invasiva

Contexto Operacional: Um E-commerce emprega algoritmos para recomendação automatizada. Os logs de navegação (cliques, tempo em tela, carrinhos abandonados) são consolidados num bucket da AWS acessível, sem criptografia, a toda a estrutura de Marketing.

Incidente de Relações Públicas:

O modelo matemático correlacionou a compra sistemática de suplementos sem odor, cremes hidratantes e algodão, inferindo gestação. O sistema automatizado remeteu promoções de fraldas e produtos para recém-nascidos para o endereço físico de uma adolescente, expondo sua condição aos genitores inadvertidamente.

Pauta para o Relatório (10 min):

Aponte as falhas estruturais de Controle de Acesso (IAM), governança de algoritmos e transparência de processamento presentes neste fluxo.

Gabarito: Discussão do Cenário 2

Diagnóstico Técnico e Mitigação Algorítmica:

- Quebra de Confidencialidade e IAM: O data lake de logs crus exposto indiscriminadamente fere a política do Menor Privilégio. A leitura desses dados deve ser exclusiva para Engenheiros de Dados responsáveis pela modelagem.
- Risco de Inferência Sensível: Extrair conclusões matemáticas sobre condições médicas (gestação) a partir de compras de varejo comuns, sem consentimento formal, configura violação conceitual severa.
- **Refatoração Operacional:** Adoção de Opt-in documentado para *profiling* preditivo e inserção de Safety Constraints no algoritmo. O modelo deve proibir gatilhos automatizados em categorias críticas de saúde, sobretudo associadas a perfis demográficos de menores de idade.

Resumo da Ópera

- **Responsabilidade Compartilhada:** Engenheiros e Cientistas de Dados são "Operadores" na visão da lei. Decisões arquiteturais falhas afetam o balanço financeiro e a reputação da companhia.
- **Auditoria e Minimização:** Sistemas que não limitam o escopo de coleta e não logam extrações (O famigerado botão "Baixar CSV") estão fadados a expor informações.
- **As Inferências da IA:** IAs são eficientes na descoberta de padrões. A correlação de dados não-sensíveis pode facilmente revelar dados sensíveis, exigindo governança severa nos parâmetros de treinamento.

Aprofundamento Recomendado

Extensão da Prática Profissional



Documentação

Guias Oficiais da ANPD

A Autoridade Nacional disponibiliza frameworks práticos voltados à TI para a Anonimização e proteção.



Stack Python

Biblioteca Faker

Gerador robusto de *mock data* (nomes, CPFs, RGs sintéticos) indispensável para povoar ambientes de desenvolvimento e *Staging*.



Estudo de Caso

Privacidade Hackeada

O documentário destrincha a mecânica de inferência algorítmica utilizada no incidente da Cambridge Analytica.

Cenas do Próximo Capítulo

Lidando com a Complexidade Estatística

Finalizamos o bloco fundacional. A partir da próxima semana, os laboratórios migram inteiramente para o código computacional.

- População, Amostra e os perigos do Viés de Seleção.
- Inauguração do ambiente em Nuvem (Google Colab).
- **Necessário: Dispositivo com acesso à conta Google corporativa/pessoal na próxima aula.**